



CYBER THREAT INTELLIGENCE REPORT

능동적으로 악용 중인 3대 취약점 통합 분석

Microsoft Defender 제로데이 · n8n Ni8mare · Trend Micro Apex One

엔드포인트 보안 솔루션·자동화 허브·EDR 관리 콘솔을 노린
'방어 계층 자체'에 대한 공격면 확산

리포트 ID **CTI-2026-0522-EDR3** | 분류 **TLP:GREEN** | 심각도 **HIGH**

Dennis Kim (김호광 / HoKwang Kim)

Independent Cyber Threat Intelligence Analyst

발행일 2026년 5월 22일

문서 정보

리포트 ID	CTI-2026-0522-EDR3
분류 (Classification)	TLP:GREEN — 대외 공유 가능 (출처 표기 필수)
심각도 (Severity)	HIGH — 보안 인프라·자동화 인프라 광범위 영향, 다수 항목 실제 악용 확인
대상 산업 (Target Sector)	전 산업 (엔드포인트 보안 운영) · DevOps/자동화 · MSP·EDR 운영 조직
커버 CVE	CVE-2026-41091, CVE-2026-45498, CVE-2026-45584 (MS Defender) · CVE-2026-21858, CVE-2025-68613 (n8n) · CVE-2026-34926 (Trend Micro Apex One)
악용 상태	Defender 2 건 in-the-wild 악용(CISA KEV) · Apex One in-the-wild 악용 (CISA KEV) · n8n 공개 PoC 익스플로잇 체인 존재
작성일 (Publication)	2026 년 5 월 22 일
발행 (Publisher)	Dennis Kim — CYBER-THREAT-INTELLIGENCE-REPORT

작성 의도. 본 리포트는 2026 년 5 월 셋째 주 기준으로 국내 언론 보도가 제한적이면서 실제 공격에 악용 중이거나 공개 익스플로잇이 존재하는 세 건의 취약점을 통합 분석한다. 세 사건은 표면적으로 무관해 보이나, 공통적으로 '방어·자동화 계층 그 자체'를 공격면으로 삼는다는 점에서 2026 년 위협 트렌드의 한 단면을 보여준다.

목차

문서 정보.....	1
목차.....	1
1. 경영진 요약 (Executive Summary).....	1
핵심 판단 (Key Judgments).....	1
2. 통합 개요 — 세 취약점 한눈에 보기.....	1
3. Microsoft Defender 제로데이 (CVE-2026-41091 / -45498 / -45584).....	1
3.1 개요.....	1
3.2 기술 분석.....	1
3.3 영향 받는 버전 및 수정본.....	1
4. n8n 'Ni8mare' (CVE-2026-21858) — 비인증 RCE 체인.....	1
4.1 개요.....	1
4.2 기술 분석 — Content-Type 혼동에서 RCE 까지.....	1
4.3 노출 면과 현실적 위험도.....	1
5. Trend Micro Apex One (CVE-2026-34926) — 관리 콘솔 디렉터리 트래버설.....	1
5.1 개요.....	1
5.2 기술 분석 및 맥락.....	1
5.3 노출 면과 대응 전제.....	1
6. 침해 지표 (IoC) 및 MITRE ATT&CK 매핑.....	1
6.1 MITRE ATT&CK 매핑.....	1
6.2 탐지·헌팅 권고.....	1
7. 대응 조치 및 보안 권고사항.....	1
7.1 P0 — 즉시 조치.....	1
7.2 P1 — 24~72 시간.....	1
7.3 P2 — 구조적 개선.....	1
8. Web3·자동화 인프라 및 한국 관점.....	1
8.1 Web3·자동화 인프라 고유 리스크.....	1
8.2 한국 기업·기관 관점 권고.....	1
9. 결론 및 전략적 시사점.....	1
10. 참고 문헌 및 출처.....	1
10.1 Microsoft Defender.....	1
10.2 n8n Ni8mare.....	1
10.3 Trend Micro Apex One 및 KEV.....	1
부록 A. 용어 정리.....	1

1. 요약 (Executive Summary)

2026년 5월 셋째 주, 보안 운영의 '최후 방어선' 또는 '신경계'에 해당하는 세 종류의 제품에서 고위험 취약점이 동시다발적으로 부각되었다.

(1) Microsoft Defender — 안티멀웨어 엔진·플랫폼의 제로데이 2건이 5월 19일 공개와 동시에 실제 악용이 확인되어 미국 CISA의 KEV(Known Exploited Vulnerabilities) 목록에 등재되었다.

(2) n8n — 100 만 회 이상 Docker 풀을 기록한 워크플로 자동화 플랫폼에서 CVSS 만점(10.0)의 비인증 원격 코드 실행 결함이 공개 PoC 익스플로잇 체인과 함께 확산되었다.

(3) Trend Micro Apex One — 다수 기업이 사용하는 엔드포인트 보안 관리 콘솔의 디렉터리 트래버설 취약점이 5 월 21 일 실제 악용 근거와 함께 KEV 에 추가되었다.

△ 핵심 리스크. 세 사건의 공통점은 공격자가 '보호 장치(Defender)·자동화 허브(n8n)·중앙 관리 콘솔(Apex One)'처럼 이미 높은 신뢰와 권한을 부여받은 구성요소를 표적으로 삼는다는 것이다. 이런 구성요소의 침해는 권한 상승, 보호 무력화, 횡적 확산의 폭발 반경(blast radius)이 비정상적으로 크다.

핵심 판단 (Key Judgments)

#	판단	근거 및 신뢰도
KJ-1	Microsoft Defender 제로데이 2 건(CVE-2026-41091, CVE-2026-45498)은 공개 시점에 이미 실제 공격에 악용되고 있었다.	Microsoft 보안 권고가 악용 사실을 인정했고, CISA 가 KEV 에 등재. 신뢰도: 높음(High)
KJ-2	Defender LPE(CVE-2026-41091)는 '초기 침투 후 SYSTEM 권한 확보' 단계에 직접 쓰이는 전형적 post-exploitation 도구다.	CWE-59 링크 팔로잉, 낮은 권한·무사용자상호작용·낮은 복잡도. mpengine.dll 에 위치. 신뢰도: 높음
KJ-3	Defender 익스플로잇은 'Nightmare Eclipse'가 공개한 RedSun/UnDefend 도구와 연관됐을 개연성이 있다.	복수 보안 매체가 연관성 제기. 단, Microsoft 는 공식 명명하지 않음. 신뢰도: 중간(Medium)
KJ-4	n8n Ni8mare(CVE-2026-21858)는 인터넷 노출 인스턴스에서는 비인증 RCE, 내부 배치 시에는 강력한 침투 후 가속기로 작동한다.	Cyera 원 연구 + 공개 PoC 체인(CVE-2025-68613 연계). Armis 는 '내부 배치가 일반적' 이라 평가. 신뢰도: 높음
KJ-5	Trend Micro Apex One(CVE-2026-34926)의 KEV 등재는 '보안 제품이 곧 공격 인프라'라는 추세를 재확인한다.	CISA 가 2026-05-21 실제 악용 근거로 등재. Apex 제품군 KEV 등재는 누적 10 건 이상. 신뢰도: 높음
KJ-6	세 사건 모두 한국 기업·기관에 직접 적용되는 위협이나, 국내 매체 보도는 제한적이어서 인지·대응 격차가 존재한다.	국내 주요 보안 매체 검색상 단독·심층 보도 부재. 발행 시점 평가. 신뢰도: 중간

2. 통합 개요 - 세 취약점 한눈에 보기

아래 표는 본 리포트가 다루는 세 취약점의 핵심 속성을 비교한 것이다. 이후 섹션 3~5 에서 각각을 상세 분석한다.

구분	MS Defender	n8n (Ni8mare)	Apex One
대표 CVE	CVE-2026-41091	CVE-2026-21858	CVE-2026-34926
CVSS	7.8 (High)	10.0 (Critical)	미공개(Directory Traversal)
취약점 유형	권한 상승(LPE) · 링크 팔로잉(CWE-59)	비인증 RCE · Content-Type 혼동	디렉터리 트래버설(CWE-22)
악용 상태	실제 악용(KEV 등재)	공개 PoC 익스플로잇 체인	실제 악용(KEV 등재)
선결 조건	낮은 권한 로컬 접근	네트워크 도달성(취약 워크플로)	관리 콘솔 접근
주요 영향	SYSTEM 권한 획득 / 방어 무력화	인스턴스 완전 탈취 / 크리덴셜 유출	에이전트로 악성코드 배포
대응 핵심	MPE/플랫폼 즉시 업데이트	1.121.0+ 업그레이드, 폼·웹훅 차단	최신 빌드 적용, 콘솔 노출 차단

관통하는 메시지: "방어 계층은 가장 신뢰받기에, 침해되면 가장 위험하다." 안티멀웨어 엔진, 자동화 오케스트레이터, EDR 관리 콘솔은 모두 광범위한 권한·데이터·실행 능력을 전제로 동작한다. 공격자는 경계를 뚫는 대신, 이미 경계 안에서 신뢰받는 이 구성요소들을 노린다.

3. Microsoft Defender 제로데이 (CVE-2026-41091 / -45498 / -45584)

3.1 개요

2026년 5월 19일 공개된 Microsoft Defender 관련 취약점 중 **CVE-2026-41091**(권한 상승, **CVSS 7.8**)과 **CVE-2026-45498**(서비스 거부, **CVSS 4.0**) 두 건이 공개 시점에 이미 실제 공격에 악용 중인 것으로 확인되었다. Microsoft가 이를 권고에서 인정했고, 미국 CISA가 두 건을 모두 KEV 목록에 등재해 실환경 악용을 공식화했다. 함께 패치된 **CVE-2026-45584**는 안티멀웨어 엔진의 원격 코드 실행 취약점이다.

3.2 기술 분석

3.2.1 CVE-2026-41091 — 링크 팔로잉 기반 SYSTEM 권한 상승

이 취약점은 Defender의 스캔·탐지·치료를 담당하는 **Microsoft Malware Protection Engine(MPE, mpengine.dll)**이 파일에 접근하기 전 링크(심볼릭 링크·정션)를 올바르게 해석하지 못하는 결함(CWE-59, link following)에서 비롯된다. 인증된 로컬 공격자는 Defender가 공격자 통제 경로를 따라가도록 조작해, 결과적으로 **SYSTEM 권한**을 획득할 수 있다. 낮은 권한·무사용자상호작용·낮은 공격 복잡도 조합이어서, 이미 발판을 마련한 공격자에게 신뢰성 높은 권한

상승 수단이 된다.

주의할 운영상 함정: Defender 가 비활성화된 시스템에서도 설치된 바이너리의 버전 검사 때문에 스캔 결과에 '취약'으로 표기될 수 있다. 그러나 이 경우 실제 악용 가능 상태는 아니다. 자산 인벤토리상 오탐을 우려 등급 판단과 혼동하지 않아야 한다.

3.2.2 CVE-2026-45498 — Defender 서비스 거부

실시간 보호를 담당하는 **Microsoft Defender Antimalware Platform(MsMpEng.exe)** 계열에 영향을 주는 DoS 취약점이다. CVSS 는 4.0 으로 낮지만, 무권한·무사용자상호작용으로 로컬에서 트리거 가능하며, **보호 기능 자체를 불능화**해 후속 공격의 사전 정지 작업으로 악용될 수 있다는 점에서 단순 점수 이상의 의미를 가진다. 기밀성·무결성에는 직접 영향이 없으나, 사고 대응·탐지 역량을 마비시킬 수 있다.

3.2.3 익스플로잇 출처 정황 — RedSun / UnDefend

복수 보안 매체는 두 결함이 지난달 'Nightmare Eclipse'를 자처하는 연구자가 GitHub 에 공개한 **RedSun · UnDefend** 익스플로잇과 연관됐을 개연성을 제기했다. Microsoft 는 권고에서 해당 익스플로잇 명칭을 직접 언급하지 않았으므로, 귀속(attribution)은 정황 수준으로 보아야 한다.

3.3 영향 받는 버전 및 수정본

구성요소	영향 버전	수정 버전
Malware Protection Engine	v1.1.26030.3008 이하	v1.1.26040.8
Antimalware Platform	v4.18.26030.3011 이하	v4.18.26040.7

실무 메모.

MPE/플랫폼은 통상 자동 업데이트되지만, 격리망·이미지 고정 환경·System Center 계열(SCEP 2012/2012 R2 등)·Security Essentials 를 쓰는 레거시 자산은 자동 갱신이 지연되거나 누락될 수 있다. 이런 자산을 우선 점검하라.

4. n8n 'Ni8mare' (CVE-2026-21858) — 비인증 RCE 체인

4.1 개요

n8n은 노드 기반 비주얼 인터페이스의 로우코드 워크플로 자동화 플랫폼으로, Salesforce·Slack·OpenAI·내부 서비스를 연결하는 **자동화 허브** 역할을 한다. 1억 회 이상의 Docker 풀과 약 10만 개의 자체 호스팅 인스턴스가 추정된다. Cyera Research Labs의 Dor Attias가 발견·제보(2025-11-09)했고 'Ni8mare'로 명명되었으며, CVSS는 **만점 10.0**이다. n8n은 2025-11-18 버전 1.121.0으로 수정본을 배포했고, 2026-01-07 정식 권고를 공개했다.

4.2 기술 분석 — Content-Type 혼동에서 RCE 까지

근본 원인은 폼 웹훅(Form Webhook) 노드가 파일 업로드를 처리할 때 **Content-Type**이 **multipart/form-data** 인지 검증하지 않는 데 있다. 공격자가 Content-Type 헤더를 조작하면 n8n이 잘못된 파서를 호출하게 되고, 내부 요청 파싱 상태(req.body.files 등 내부 JSON 객체)를 덮어쓸 수 있다. 이를 통해 다음 체인이 성립한다.

단계	기법	결과
Step 1	Content-Type 혼동(CVE-2026-21858)	임의 파일 읽기(Arbitrary File Read)
Step 2	설정 파일·데이터베이스 탈취	관리자 JWT 위조(세션 탈취)
Step 3	표현식 인젝션(CVE-2025-68613) → 샌드박스 우회	원격 코드 실행(RCE) · 인스턴스 완전 장악

공개 PoC 현황: 공개 디스클로저 약 9시간 만에 패치 diff 분석을 통해 재현·익스플로잇이 제작된 사례가 보고되었다(특정 워크플로 구성이 필요한 조건부 PoC). 즉, 이 취약점은 **이론적 위험이 아니라 실제 도구화가 진행된 단계에 있다**.

4.3 노출 면과 현실적 위험도

Armis 등은 "CVSS 10.0"이라는 표현이 오히려 현실을 가린다고 지적한다. 다수 조직에서 n8n은 인터넷에 직접 노출되지 않고 **내부 자동화 서비스(사설망·VPN·신뢰 클라우드 세그먼트)**로 배치된다. 이 경우 Ni8mare는 '초기 침투' 취약점이 아니라, 공격자가 이미 내부에 진입한 뒤 **폭발 반경을 극적으로 키우는 침투 후 가속기(post-compromise accelerator)**로 작동한다. n8n이 저장된 크리덴셜과 실행 권한을 다수 보유하기 때문이다.

영향 버전: 주로 자체 호스팅 1.65.0 ~ 1.120.4 구간이 영향을 받으며, 1.121.0 이상에서 수정되었다. 클라우드 인스턴스는 자동 패치되었다. 연계 체인에 쓰이는 **CVE-2025-68613**(인증된 표현식 인젝션) 및 별도 RCE-via-Arbitrary-File-Write(CVE-2026-21877, CVSS 9.9)도 함께 점검 대상이다.

5. Trend Micro Apex One (CVE-2026-34926) — 관리 콘솔 디렉터리 트래버설

5.1 개요

2026년 5월 21일, CISA는 **Trend Micro Apex One(온프레미스)**의 디렉터리 트래버설 취약점 **CVE-2026-34926**을 실제 악용 근거와 함께 KEV 목록에 추가했다(같은 날 Langflow CVE-2025-34291도 동시 등재). Apex One은 랜섬웨어 방어·제로데이 방어·EDR·DLP·가상 패치를 단일 에이전트로 제공하는 **엔드포인트 보안 관리 솔루션**으로, 관리 콘솔이 다수 엔드포인트 에이전트를 중앙에서 통제한다.

5.2 기술 분석 및 맥락

CVE-2026-34926은 관리 콘솔의 키 테이블을 조작해 악성 코드를 주입하고, 이를 영향받는 설치의 **에이전트로 배포**할 수 있는 디렉터리 트래버설(CWE-22) 결함이다. 보안 관리 콘솔이 침해되면, '보호하던 모든 단말'이 곧 '공격 배포 채널'로 전환된다는 점이 핵심 위험이다.

앞선 2026년 2월 권고에서 Trend Micro는 동일 콘솔의 비인증 디렉터리 트래버설 RCE 2건 (CVE-2025-71210, CVE-2025-71211, 각 CVSS 9.8)을 패치한 바 있으며, 당시 외부에 노출된 콘솔 IP가 위험을 키운다고 경고했다. Apex 제품군은 **CISA KEV**에 누적 **10건 이상**이 등재될 만큼 공격자가 반복적으로 노려온 표적이다.

정정 노트.

초기 브리핑에서 언급된 'Apex One 사전 인증 로컬 디렉터리 트래버설(별도 CVE)'은 이번 KEV 실제 악용 등재 건과 다른 항목이다. 본 리포트가 다루는 **실제 악용 확인 + 2026-05-21 KEV 등재** 건은 CVE-2026-34926이다. 운영 우선순위 판단 시 CVE 식별자를 정확히 구분할 것.

5.3 노출 면과 대응 전제

악용은 **관리 콘솔 접근**을 전제로 한다. 따라서 콘솔을 인터넷에 직접 노출하지 않고, 출처 IP 제한(source restriction)과 망 분리를 적용하는 것이 1차 방어선이다. 온프레미스 사용자는 최신 빌드로 업데이트해야 하며, SaaS(Trend Vision One Endpoint) 사용자는 별도 조치가 필요 없는 경우가 많으나 공지로 확인할 것.

6. 침해 지표 (IoC) 및 MITRE ATT&CK 매핑

아래 매핑은 공개 권고·연구 자료에 기반한 방어용 참고 지표다. 환경별로 탐지 룰을 검증한 뒤

적용할 것.

6.1 MITRE ATT&CK 매핑

ATT&CK ID	Tactic / Technique	적용 사건
T1068	Exploitation for Privilege Escalation	Defender LPE(CVE-2026-41091) → SYSTEM
T1574.005	Hijack Execution Flow: Symlink/Link Following	Defender 링크 팔로잉(CWE-59)
T1562.001	Impair Defenses: Disable or Modify Tools	Defender DoS(CVE-2026-45498)로 보호 무력화
T1190	Exploit Public-Facing Application	n8n 인터넷 노출 인스턴스 비인증 RCE
T1083 / T1005	File & Directory Discovery / Data from Local System	n8n·Apex One 임의 파일 읽기·트래버설
T1552.001	Unsecured Credentials: Credentials in Files	n8n 설정·DB에서 시크릿 탈취 → JWT 위조
T1059	Command and Scripting Interpreter	n8n 표현식 인젝션(CVE-2025-68613) RCE
T1505 / T1570	Server Software Component / Lateral Tool Transfer	Apex One 콘솔 → 에이전트 악성코드 배포

6.2 탐지·헌팅 권고

- **n8n 웹훅:** non-multipart Content-Type 요청이 파일 업로드 내부 객체를 참조하는 비정상 패턴 탐지(Armis 공개 룰 개념). 정상 웹훅 트래픽과 구분되는 행위 기반 시그니처를 우선.
- **Defender:** MPE/플랫폼 버전이 수정본 미만인 자산 식별, 비표준 경로를 향한 심볼릭 링크·정션 생성 이벤트, MsMpEng 비정상 종료/응답 불능 모니터링.
- **Apex One:** 관리 콘솔에 대한 비인가 HTTP 요청, 경로 트래버설 시퀀스(../, 인코딩 변형), 콘솔발 비정상 에이전트 배포·정책 변경 이벤트 검토.
- **공통:** 외부 노출된 관리·자동화 인터페이스(n8n 폼/웹훅, Apex One 콘솔)의 인터넷 도달성 여부를 자산 스캐닝으로 즉시 확인.

7. 대응 조치 및 보안 권고사항

우선순위는 P0(즉시) · P1(24~72 시간) · P2(7 일 내 구조 개선)로 구분한다.

7.1 P0 — 즉시 조치

#	대상	조치
P0-1	Defender	Malware Protection Engine v1.1.26040.8 / Antimalware Platform v4.18.26040.7 이상으로 갱신 확인. 격리망·이미지 고정·레거시(SCEP/Security Essentials) 자산 우선 점검.
P0-2	n8n	자체 호스팅 인스턴스를 1.121.0 이상으로 즉시 업그레이드. 불가 시 공개 웹훅·폼 엔드포인트를 임시 차단(공식 우회책 없음).
P0-3	Apex One	온프레미스 콘솔을 최신 빌드로 업데이트. 콘솔의 인터넷 노출 즉시 차단 및 출처 IP 제한 적용.
P0-4	공통	세 제품의 관리/자동화 인터페이스가 외부에 노출됐는지 외부 관점 스캔으로 확인하고 노출 제거.

7.2 P1 — 24~72 시간

#	조치
P1-1	n8n 인스턴스의 저장 크리덴셜 전수 점검 및 회전. 침해 가정 시 연동된 외부 서비스 토큰(Slack·Salesforce·LLM API 등)도 회전.
P1-2	Defender 악용 정황(비정상 SYSTEM 권한 프로세스, 보호 비정상 종료)에 대한 EDR 소급 헌팅 14~30 일.
P1-3	Apex One 콘솔 인증 로그·정책 변경 이력·에이전트 배포 이력에서 비정상 활동 검토.
P1-4	연계 CVE(n8n CVE-2025-68613·CVE-2026-21877, Defender CVE-2026-45584) 패치 적용 여부 확인.

7.3 P2 — 구조적 개선

- 관리·자동화 평면 분리: n8n·EDR 콘솔 등 고권한 인터페이스를 사설망/제로트러스트 게이트웨이 뒤로 이전하고, 인터넷 직접 노출을 표준적으로 금지.
- 최소권한·자동화 거버넌스: n8n 워크플로가 보유한 크리덴셜과 실행 권한을 점검해 폭발 반경을 축소. 자동화 허브를 '최고 권한 내부자'로 간주한 위협 모델 수립.
- 보안 제품의 패치 SLA: 안티멀웨어 엔진·EDR 콘솔 등 '방어 계층' 자체를 별도 고우선순위 패치 트랙으로 운영. KEV 등재 항목은 즉시 대응 기준 적용.
- 탐지 가시성 이중화: 단일 보호 제품(Defender) 무력화 시에도 탐지가 가능하도록 로그 중앙화·이중 EDR/네트워크 탐지 등 다층화.

8. Web3·자동화 인프라 및 한국 관점

8.1 Web3·자동화 인프라 고유 리스크

자동화 허브(n8n)는 Web3 운영에서도 빠르게 채택되고 있어, 침해 시 다음과 같은 도메인 특화 위험이 발생한다.

리스크	시나리오
온체인 자동화 키 노출	n8n 워크플로에 저장된 핫월렛 키·서명 봇 크리덴셜·거래소 API 키가 임의 파일 읽기로 유출되면 직접적 자산 탈취로 이어질 수 있다.
배포·알림 파이프라인 변조	토큰 발행·에어드롭·모니터링 알림이 n8n 으로 자동화된 경우, 인스턴스 장애는 잘못된 트랜잭션 트리거나 경보 무력화로 연결된다.
EDR 무력화 후 침투	운영 단말의 Defender/Apex One 가 무력화되면, 키 관리·서명 워크스테이션이 무방비 상태로 노출된다.

8.2 한국 기업·기관 관점 권고

대상	권고
일반 기업·공공	Defender·Apex One 는 국내 도입률이 높은 제품군이다. KEV 등재 항목을 국내 패치 우선순위 체계에 즉시 반영하고, 자산 인벤토리로 영향 버전을 식별할 것.
MSP·관제(SOC)	고객사 EDR 관리 콘솔(Apex One 등)의 외부 노출 여부를 일괄 점검. 콘솔 침해는 다수 고객사로의 동시 확산 위험이 있어 공급망 관점에서 다룰 것.
DevOps·자동화 운영	사내 n8n 등 자동화 허브의 버전·노출·저장 크리덴셜을 전수 조사. '편의를 위한 자동화'가 단일 침해점이 되지 않도록 격리.
Web3 발행사·거래소	운영 자동화에 사용하는 n8n 류 도구와 서명 워크스테이션의 보호 솔루션 상태를 함께 점검. DAXA 보안 점검 체크리스트에 '자동화 인프라·EDR 콘솔 노출' 항목 추가 검토.

제언. 국내에서는 이번 세 사건이 개별 단신으로도 잘 다뤄지지 않았다. 그러나 세 제품 모두 한국 기업·기관의 **실제 운영 스택에 광범위하게 존재**한다. '국내 보도 부재'가 '국내 무관'을 의미하지 않는다는 점을, 보안 책임자는 자산 기반으로 재확인해야 한다.

9. 결론 및 전략적 시사점

본 리포트가 묶은 세 취약점은 우연한 동시성에 그치지 않고, 2026년 위협의 한 방향성을 드러낸다. 즉, 공격자가 경계를 정면 돌파하기보다 이미 신뢰받는 '방어·자동화·관리 계층'을 표적으로 삼는 추세다.

교훈 1 - 보호 장치가 가장 매력적인 표적이다

안티멀웨어 엔진·EDR 콘솔은 정의상 높은 권한으로 시스템 전반에 접근한다. 이들의 LPE·트래버설은 곧 SYSTEM 권한 또는 다수 단말 통제로 직결된다. 보안 제품이라는 이유로 패치를 후순위에 두는 관행은 위험하다.

교훈 2 - 자동화 허브는 '최고 권한 내부자'다

n8n 처럼 다수 시스템의 크리덴셜과 실행 권한을 보유한 자동화 플랫폼은, 단일 침해가 조직 전반으로 즉시 확산되는 폭발 반경을 가진다. 인터넷 노출이 아니더라도 침투 후 가속기로서의 위험을 별도로 모델링해야 한다.

교훈 3 - KEV 는 '체크리스트'가 아니라 '실시간 지도'다

CISA KEV 등재는 '악용 여부 논쟁의 종료'를 뜻한다. Defender·Apex One 의 신속한 KEV 등재가 보여주듯, KEV 를 패치 우선순위 입력값으로 상시 연동하는 운영 체계가 필요하다.

최종 판단. 세 항목 중 Defender 2 건과 Apex One 1 건은 **실제 악용이 확인된 KEV 등재 건**으로 최우선 대응 대상이다. n8n Ni8mare 는 공개 PoC 체인이 존재하는 만큼, 자체 호스팅 인스턴스 보유 조직은 즉시 패치·노출 차단을 권고한다. 본 리포트는 추가 정보 확보 시 갱신될 예정이다.

10. 참고 문헌 및 출처

본 리포트는 2026년 5월 공개된 1차 권고(Microsoft MSRC, CISA KEV, n8n·Trend Micro 보안 권고)와 전문 보안 매체의 2차 자료를 교차 검증해 작성되었다.

10.1 Microsoft Defender

1. The Hacker News, "Microsoft Warns of Two Actively Exploited Defender Vulnerabilities". <https://thehackernews.com/2026/05/microsoft-warns-of-two-actively.html>
2. BleepingComputer, "Microsoft warns of new Defender zero-days exploited in attacks". <https://www.bleepingcomputer.com/news/security/microsoft-warns-of-new-defender-zero-days-exploited-in-attacks/>
3. Help Net Security, "Microsoft Defender vulnerabilities exploited in the wild". <https://www.helpnetsecurity.com/2026/05/21/microsoft-defender-vulnerabilities-cve-2026-41091-cve-2026-45498/>
4. CSO Online, "Microsoft patches two zero-day flaws in Defender". <https://www.csoonline.com/article/4175970/microsoft-patches-two-zero-day-flaws-in-defender.html>
5. SecurityWeek, "Microsoft Patches Exploited UnDefend and RedSun Defender Zero-Days". <https://www.securityweek.com/microsoft-patches-exploited-undefend-and-redsun-defender-zero-days/>

10.2 n8n Ni8mare

6. The Hacker News, "Critical n8n Vulnerability (CVSS 10.0) Allows Unauthenticated Attackers to Take Full Control". <https://thehackernews.com/2026/01/critical-n8n-vulnerability-cvss-100.html>
7. SecurityWeek, "Critical Vulnerability Exposes N8n Instances to Takeover Attacks". <https://www.securityweek.com/critical-vulnerability-exposes-n8n-instances-to-takeover-attacks/>
8. Rapid7, "Ni8mare and N8sape flaws among multiple critical vulnerabilities affecting n8n". <https://www.rapid7.com/blog/post/etr-ni8mare-n8sape-flaws-multiple-critical-vulnerabilities-affecting-n8n/>
9. Armis, "Ni8mare in Automation". <https://www.armis.com/blog/ni8mare-in-automation/>
10. ilert Postmortem, "n8n: How the Ni8mare flaw left 100,000 servers open to total takeover". <https://www.ilert.com/postmortems/n8n-ni8mare-rce-2026-01-08>

10.3 Trend Micro Apex One 및 KEV

11. CISA, "CISA Adds Two Known Exploited Vulnerabilities to Catalog" (2026-05-21). <https://www.cisa.gov/news-events/alerts/2026/05/21/cisa-adds-two-known-exploited-vulnerabilities-catalog>
12. CISA, Known Exploited Vulnerabilities Catalog. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
13. SecurityWeek, "Trend Micro Patches Critical Apex One Vulnerabilities". <https://www.securityweek.com/trend-micro-patches-critical-apex-one-vulnerabilities/>
14. GBHackers, "Critical Trend Micro Apex One Vulnerabilities Allow Remote Malicious Code Execution". <https://gbhackers.com/critical-trend-micro-apex-one-vulnerabilities/>

부록 A. 용어 정리

용어	정의
KEV (Known Exploited Vulnerabilities)	미국 CISA 가 실환경 악용 근거가 확인된 취약점을 정리·관리하는 목록. 등재 시 연방기관에 패치 기한이 부과되며, 민간에서도 사실상 최우선 대응 기준으로 활용된다.
LPE (Local Privilege Escalation)	로컬 접근 권한을 가진 공격자가 더 높은 권한(SYSTEM/root)으로 상승하는 공격. 초기 침투 후 단계에서 흔히 사용.
링크 팔로잉 (CWE-59)	프로그램이 파일 접근 전에 심볼릭 링크·정션을 부적절하게 따라가, 의도치 않은 경로를 조작당하는 취약점 유형.
Content-Type 혼동	HTTP 요청의 Content-Type 헤더 검증 누락으로 잘못된 파서가 호출되어 내부 처리 상태가 변조되는 결함.
디렉터리 트래버설 (CWE-22)	경로 입력 검증 미흡으로 의도된 디렉터리 밖 파일에 접근·조작하는 취약점.
폭발 반경 (Blast Radius)	단일 침해가 연쇄적으로 확산되는 영향 범위. 권한·연결성이 큰 구성요소일수록 반경이 크다.
침투 후 가속기	초기 접근 자체보다는, 이미 내부에 진입한 공격자의 확산·권한 상승을 크게 가속하는 취약점·도구.
MPE (Malware Protection Engine)	Microsoft Defender 의 스캔·탐지·치료를 담당하는 핵심 엔진 컴포넌트 (mpengine.dll).

— 문서 끝 (End of Report) —

© 2026 Dennis Kim · Cyber Threat Intelligence Division

github.com/gameworkerkim/CYBER-THREAT-INTELLIGENCE-REPORT

본 리포트는 공개된 정보에 기반한 독립적 분석으로, 관련 조직의 공식 입장과 무관합니다.

TLP:GREEN · CTI-2026-0522-EDR3 · Published: 2026-05-22